

BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC VĂN HIẾN



TIỂU LUẬN KẾT THÚC HỌC PHẦN

MÔN: BẢO MẬT IOT

ĐỀ TÀI : RỦI RO THIẾT BỊ IOT

KẾT NỐI TRỰC TIẾP INTERNET

Giảng viên: ThS.Hồ Nhật Minh

Sinh viên thực hiện: Phạm Thị Tường Vi

MSSV: 231A010502

TP. HỒ CHÍ MINH - 2026

BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC VĂN HIẾN



TIỂU LUẬN KẾT THÚC HỌC PHẦN

MÔN: BẢO MẬT IOT

ĐỀ TÀI: ĐỀ TÀI : RỦI RO THIẾT BỊ IOT

KẾT NỐI TRỰC TIẾP INTERNET

TP. HCM, NĂM 2026

LỜI CẢM ƠN

Em xin gửi lời cảm ơn chân thành nhất đến Ban Giám hiệu Trường Đại học Văn Hiến, cùng các thầy cô trong khoa Công nghệ thông tin đã tận tình giảng dạy, truyền đạt cho em những kiến thức quý báu trong suốt quá trình học tập. Những kiến thức đó là nền tảng vững chắc giúp em có thể áp dụng vào thực tiễn trong tương lai.

Em xin bày tỏ lòng biết ơn sâu sắc đến Giảng viên hướng dẫn Thầy Hồ Nhật Minh, người đã tận tâm chỉ bảo và góp ý cho em trong suốt quá trình thực hiện bài tiểu luận. Sự hỗ trợ và hướng dẫn tận tình của thầy là nguồn động viên lớn giúp em hoàn thành tốt bài tiểu luận này.

Cuối cùng, em xin chân thành cảm ơn tất cả mọi người đã giúp đỡ, động viên và đồng hành cùng em trong suốt quá trình học tập và thực hiện bài tiểu luận cuối kì.

Em xin chân thành cảm ơn!

Tp.Hồ Chí Minh, ngày.....tháng.....năm.....

Sinh viên thực hiện

(Ký tên và ghi rõ họ tên)

LỜI CAM ĐOAN

Tôi xin cam đoan rằng đề tài “Rủi ro thiết bị IoT kết nối trực tiếp Internet” là kết quả của quá trình tìm hiểu, nghiên cứu và thực hiện của bản thân dưới sự hướng dẫn của giảng viên. Các nội dung trong báo cáo được xây dựng dựa trên kiến thức đã học, tài liệu tham khảo và quá trình triển khai, kiểm thử thực tế trong phạm vi đề tài.

Trong quá trình thực hiện báo cáo, tôi có sử dụng công cụ trí tuệ nhân tạo (AI) để hỗ trợ tìm hiểu kiến thức, gợi ý cách trình bày, diễn đạt nội dung và rà soát lỗi. Tuy nhiên, toàn bộ nội dung sau khi được AI hỗ trợ đều đã được tôi xem xét, chỉnh sửa và lựa chọn trước khi đưa vào báo cáo. Những phần sử dụng tài liệu từ các nguồn khác đều được trích dẫn theo quy định.

Tôi chịu hoàn toàn trách nhiệm về tính trung thực, chính xác của nội dung cũng như các số liệu, kết quả được trình bày trong báo cáo. Trường hợp có sai sót, bao gồm cả những thông tin hoặc số liệu do AI cung cấp nhưng chưa được kiểm chứng đầy đủ, tôi xin hoàn toàn chịu trách nhiệm và chấp nhận mọi hình thức xử lý theo quy định của nhà trường.

Tp.Hồ Chí Minh, ngày.....tháng.....năm.....

Sinh viên thực hiện

(Ký tên và ghi rõ họ tên)

NHẬN XÉT CỦA GIẢNG VIÊN HƯỚNG DẪN

Tp.Hồ Chí Minh, ngày.....tháng.....năm.....

Giảng viên hướng dẫn

(Ký tên và ghi rõ họ tên)

MỤC LỤC

CHƯƠNG 1: GIỚI THIỆU TỔNG QUAN	1
1.1. Bối cảnh và lý do chọn đề tài	1
1.2. Mục tiêu của đề tài	1
1.3. Đối tượng, phạm vi và giới hạn an toàn	2
1.4. Sản phẩm và kết quả dự kiến	2
1.6. Cấu trúc báo cáo	3
CHƯƠNG 2: CƠ SỞ LÝ THUYẾT VÀ MÔ HÌNH BẢO MẬT	4
2.1. Bối cảnh và Kiến trúc hệ thống IoT (IP Camera)	4
2.2. Các khái niệm bảo mật cốt lõi	5
2.3. Mô hình tấn công, rủi ro và phòng chống	5
2.4. Trọng tâm	9
2.5. Tiểu kết Chương 2	9
CHƯƠNG 3: CÁC PHƯƠNG PHÁP, MÔ HÌNH, THIẾT KẾ VÀ KẾ HOẠCH ĐÁNH GIÁ	10
3.1. Phương pháp thực hiện	10
3.2 Mô hình/kiến trúc đề xuất	11
3.3. Môi trường, công cụ, dữ liệu	14
3.4. Quy trình triển khai/đánh giá	15
3.5. Tiêu chí và Ngưỡng đánh giá (Evaluation Criteria)	17
CHƯƠNG 4: TRIỂN KHAI VÀ KẾT QUẢ	17
4.1. Chuẩn bị môi trường và Cài đặt công cụ	17
4.2. Thành phẩm sản phẩm và cấu trúc lưu trữ	18
4.3. Kịch bản thử nghiệm	20

4.4. Checklist cấu hình an toàn	28
4.5. Thảo luận & hạn chế	29
4.5.1. Thảo luận kết quả	29
4.5.2. Hạn chế	29
CHƯƠNG 5: ĐÁNH GIÁ BẢO MẬT	30
5.1. Phân loại tài sản và yêu cầu bảo mật	30
5.2. Biện pháp giảm thiểu và Hạn chế	31
CHƯƠNG 6: KẾT LUẬN	33
6.1. Đối chiếu kết quả thực hiện với mục tiêu đề tài	33
6.2. Hạn chế	34
TÀI LIỆU THAM KHẢO	36

PHỤ LỤC HÌNH ẢNH

Hình 2.1 - Sơ đồ kiến trúc hệ thống IP Camera mở cổng trực tiếp ra Internet và ranh giới tin cậy	4
Hình 2.2: Sơ đồ Cây tấn công	7
Hình 3.1:Sơ đồ mạng so sánh giữa việc cấu hình sai (Port Forwarding) ..	12
Hình 3.2: Sơ đồ cấu hình an toàn (dùng VPN/VLAN).	13
Hình 4.1:Cài đặt Python vào máy tính	21
Hình 4.2: Tạo file để chạy camera ảo	21
Hình 4.3: Nội dung của file fake_camera.py	22
Hình 4.4:Khởi chạy camera ảo	22
Hình 4.5: Cài đặt phần mềm Nmap trên trang web chính thức	23
Hình 4.6: Nmap quét rà soát và tìm được camera không có bảo mật hiện tại.	23
Hình 4.7: Cài đặt Wireshark trên trang trình duyệt	24
Hình 4.8: Wireshark bắt đầu bắt gói tin của camera.	25
Hình 4.9: Đăng nhập trình duyệt	25
Hình 4.10: Kết quả bắt gói tin bằng Wireshark cho thấy thông tin đăng nhập (Basic Auth) bị lộ.	26
Hình 4.11: Cài đặt Burp-Suite trên trình duyệt	26
Hình 4.12: Trình duyệt bị treo do chặn gói tin bị chặn.	27
Hình 4.13: Cấu hình module Intruder trên Burp Suite để thực hiện tấn công Brute-force.	28
Hình 4.14: Tự động dò quét và bẻ khóa thành công tài khoản quản trị viên.	28

PHỤC LỤC BẢNG BIỂU

Bảng 1.1: Bảng mục tiêu cần thực hiện	1
Bảng 2.1: Đánh giá rủi ro theo mô hình STRIDE	7
Bảng 2.2. Các đặc trưng được sử dụng trong quá trình thực nghiệm tấn công	9
Bảng 3.1. Thành phần, công cụ và dữ liệu	14
Bảng 3.2. Quy trình thực hiện	15
Bảng 3.3: Tiêu chí và Ngưỡng đánh giá	17
Bảng 5.1: Phân loại tài sản và yêu cầu bảo mật	30
Bảng 5.4. Biện pháp giảm thiểu và ưu tiên	31
Bảng 6.1. Bảng đối chiếu kết quả thực hiện với mục tiêu đề tài	33

BẢNG CHÚ THÍCH TỪ VIẾT TẮT VÀ ANH – VIỆT

Từ viết tắt / Thuật ngữ	Tiếng Anh (Nguyên nghĩa)	Giải nghĩa Tiếng Việt
IoT	Internet of Things	Internet vạn vật / Mạng lưới thiết bị kết nối Internet
IP	Internet Protocol	Giao thức Internet
VPN	Virtual Private Network	Mạng riêng ảo (Đường hầm mã hóa dữ liệu)
VLAN	Virtual Local Area Network	Mạng cục bộ ảo (Dùng để cô lập thiết bị mạng)
LAN	Local Area Network	Mạng nội bộ / Mạng cục bộ (Dùng trong nhà/công ty)
WAN	Wide Area Network	Mạng diện rộng (Mạng Internet toàn cầu)
NAT	Network Address Translation	Biên dịch địa chỉ mạng
Port Forwarding	Port Forwarding	Chuyển tiếp cổng (Kỹ thuật mở cổng từ LAN ra Internet)
HTTP	HyperText Transfer Protocol	Giao thức truyền tải siêu văn bản (Không mã hóa)
HTTPS	HTTP Secure	Giao thức truyền tải siêu văn bản an toàn (Có mã hóa)
Basic Auth	Basic Authentication	Phương thức xác thực cơ bản (Gửi mật khẩu bản rõ)
Sniffing	Packet Sniffing	Đánh hơi / Bắt lén gói tin trên đường truyền mạng
Brute-force	Brute-force Attack	Tấn công vét cạn (Thử sai mật khẩu liên tục)
Payload	Payload	Phần dữ liệu mang tính sát thương trong gói tin tấn công
IDS	Intrusion Detection System	Hệ thống phát hiện xâm nhập
C-I-A	Confidentiality, Integrity, Availability	Tam giác bảo mật: Tính bảo mật, Toàn vẹn, Sẵn sàng

Account Lockout	Account Lockout	Cơ chế tự động khóa tài khoản khi nhập sai mật khẩu
Localhost	Localhost	Máy chủ cục bộ (Chạy nội bộ trên chính máy tính đang dùng)
Từ viết tắt / Thuật ngữ	Tiếng Anh (Nguyên nghĩa)	Giải nghĩa Tiếng Việt
IoT	Internet of Things	Internet vạn vật / Mạng lưới thiết bị kết nối Internet
IP	Internet Protocol	Giao thức Internet
VPN	Virtual Private Network	Mạng riêng ảo (Đường hầm mã hóa dữ liệu)
VLAN	Virtual Local Area Network	Mạng cục bộ ảo (Dùng để cô lập thiết bị mạng)
LAN	Local Area Network	Mạng nội bộ / Mạng cục bộ (Dùng trong nhà/công ty)
WAN	Wide Area Network	Mạng diện rộng (Mạng Internet toàn cầu)
NAT	Network Address Translation	Biên dịch địa chỉ mạng
Port Forwarding	Port Forwarding	Chuyển tiếp cổng (Kỹ thuật mở cổng từ LAN ra Internet)

CHƯƠNG 1: GIỚI THIỆU TỔNG QUAN

Chương 1 trình bày cái nhìn bao quát nhất về bối cảnh, lý do hình thành đề tài và những vấn đề bảo mật cấp thiết đối với thiết bị mạng. Đồng thời, chương này cũng xác định rõ mục tiêu, phạm vi nghiên cứu và phác thảo các sản phẩm dự kiến sẽ đạt được làm tiền đề cho các thực nghiệm ở những chương tiếp theo.

1.1. Bối cảnh và lý do chọn đề tài

Các thiết bị IP Camera hiện nay đang được ứng dụng rộng rãi nhưng thường bị cấu hình sai lầm khi "mở cổng trực tiếp" (Port Forwarding) ra Internet để tiện giám sát từ xa. Việc này vô tình phơi bày giao diện Web và luồng phát video ra mạng công cộng, trong khi thiết bị lại thiếu mã hóa và cơ chế chống dò mật khẩu. Từ đó biến các thiết bị IoT thành mục tiêu cho các cuộc rà quét tự động của tội phạm mạng. Hậu quả là người dùng bị xâm phạm quyền riêng tư nghiêm trọng, mạng nội bộ bị lợi dụng làm bàn đạp xâm nhập. Vì vậy, đề tài "Đánh giá rủi ro thiết bị IoT kết nối trực tiếp Internet" được thực hiện để chứng minh các mối đe dọa qua thực nghiệm giả lập. Từ đó, đề tài đề xuất bộ quy tắc cấu hình an toàn (Checklist) nhằm ngăn chặn triệt để tình trạng phơi bày thiết bị, góp phần bảo vệ an ninh mạng từ hộ gia đình đến doanh nghiệp.

1.2. Mục tiêu của đề tài

Bảng 1.1: Bảng mục tiêu cần thực hiện

Mục tiêu	Đầu ra tương ứng	Cách kiểm chứng	Chương trình bày
MT-01: Xây dựng môi trường giả lập IP Camera bị phơi bày hớ hênh trên mạng.	Lập trình thành công hệ thống Web Server bằng Python chạy trên cổng 8081 với cơ chế xác thực Basic Authentication.	Lập trình kịch bản Python khởi tạo dịch vụ Web cục bộ, yêu cầu xác thực Basic Auth.	Chương 3 & Chương 4
MT-02: Chứng minh rủi ro dễ bị rà quét dịch vụ	Nmap phát hiện	Sử dụng công cụ	Chương 3 &

Mục tiêu	Đầu ra tương ứng	Cách kiểm chứng	Chương trình bày
khi cấu hình sai (Port Forwarding).	chính xác cổng 8081 đang mở (open) mà không gặp trở ngại nào.	Nmap/Zenmap dò quét dải mạng (localhost) để phát hiện dịch vụ web.	Chương 4
MT-03: Kiểm chứng rủi ro lộ lọt dữ liệu do không dùng giao thức mã hóa (SSL/TLS).	Bắt được gói tin Request và giải mã thành công thông tin đăng nhập (Plaintext).	Chạy Wireshark bắt gói tin trên card mạng Loopback và phân tích luồng HTTP Stream.	Chương 4
MT-04: Đánh giá khả năng chống chịu tấn công dò mật khẩu tự động (Brute-force).	Bẻ khóa thành công tài khoản admin:admin rất nhanh do thiếu cơ chế khóa tài khoản	Cấu hình Burp Suite Intruder chặn gói tin HTTP và bắn Payload dò mật khẩu hàng loạt.	Chương 4 & Chương 5

1.3. Đối tượng, phạm vi và giới hạn an toàn

Đối tượng nghiên cứu của đề tài là thiết bị IP Camera, tập trung vào giao thức HTTP, RTSP và dữ liệu xác thực Basic Auth, được kiểm thử thông qua các phần mềm Nmap, Wireshark và Burp Suite. Để đảm bảo tuân thủ nghiêm ngặt nguyên tắc đạo đức học thuật và giới hạn an toàn, toàn bộ quá trình thực nghiệm chỉ được triển khai khép kín trong phạm vi mạng nội bộ (Localhost) dựa trên mã nguồn Python giả lập Web Server cùng dữ liệu tài khoản giả định; đề tài cam kết tuyệt đối không thực hiện rà quét, bắt gói tin hay tấn công khai thác vào bất kỳ hệ thống hay thiết bị thực tế nào trên không gian Internet.

1.4. Sản phẩm và kết quả dự kiến

Sản phẩm dự kiến sẽ gồm:

Sơ đồ triển khai hệ thống có 1 sơ đồ mạng so sánh giữa việc cấu hình sai (Port Forwarding) và 1 sơ đồ cấu hình an toàn (dùng VPN/VLAN). Kế đó sẽ có thêm ma trận rủi ro (Risk Exposure Matrix):

Bảng ma trận rủi ro phân tích các mối đe dọa (STRIDE) và ước lượng điểm CVSS dựa trên kết quả bài thực nghiệm .

Checklist cấu hình an toàn: danh sách các bước cần thiết nhằm tránh các lỗ hổng.

Về phần thực nghiệm sẽ có các minh chứng tấn công:

Đầu tiên là mã nguồn giả lập (Code Lab): Tạo một file script là ngôn ngữ Python đóng vai trò là Web Server giả lập cho Camera IP, mở cổng 8081 và yêu cầu xác thực Basic Authentication với tài khoản mặc định (admin/admin).

Kế đó là các kết quả và quá trình thực nghiệm về dò quét mạng: Ảnh chụp màn hình phần mềm Nmap/Zenmap quét trùng IP cục bộ và báo cáo cổng 8081 đang open. Và phần bắt gói tin: ảnh chụp màn hình phần mềm Wireshark bắt được luồng đăng nhập HTTP, làm lộ header Authorization: Basic YWRtaW46YWRtaW4= (chứng minh việc truyền dữ liệu không mã hóa).

Cuối cùng là Brute-force: Ảnh chụp màn hình module Intruder của phần mềm Burp Suite, cho thấy công cụ này tự động dò trùng mật khẩu và trả về HTTP Status 200 OK (chứng minh hệ thống thiếu cơ chế khóa tài khoản khi nhập sai nhiều lần).

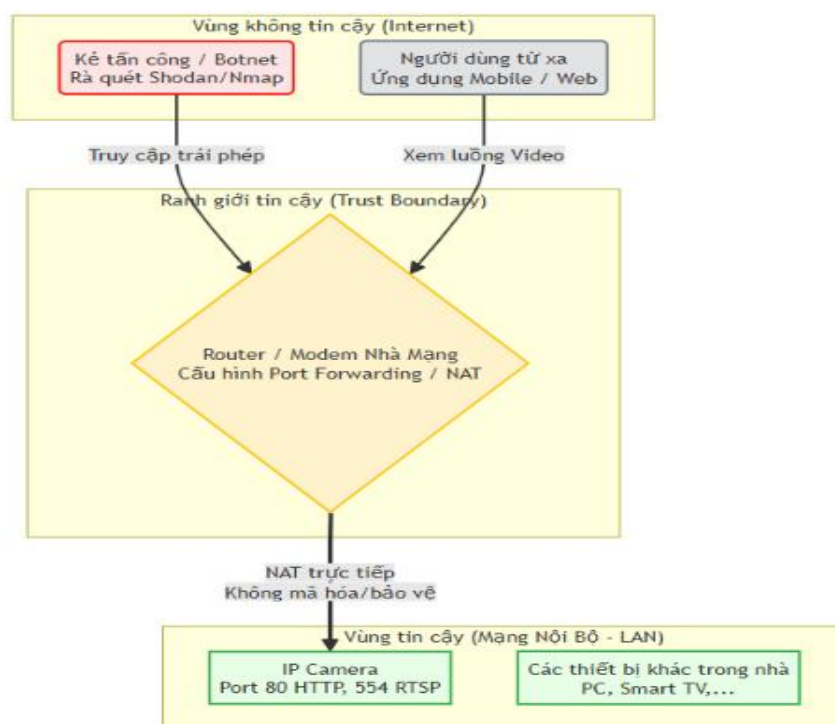
1.6. Cấu trúc báo cáo

Tiểu luận bao gồm 6 chương: Chương 1 giới thiệu vấn đề và mục tiêu. Chương 2 làm rõ cơ sở lý thuyết và các khái niệm về mạng IoT. Chương 3 trình bày sơ đồ mô hình hệ thống và phương pháp phân tích rủi ro. Chương 4 và 5 đi sâu vào phân tích rủi ro hệ thống, đối chiếu với các chuẩn OWASP để đưa ra các biện pháp giảm thiểu và checklist kiểm tra. Chương 6 đúc kết lại các kết quả đạt được.

CHƯƠNG 2: CƠ SỞ LÝ THUYẾT VÀ MÔ HÌNH BẢO MẬT

2.1. Bối cảnh và Kiến trúc hệ thống IoT (IP Camera)

Mô hình gồm các thành phần chính như máy tấn công (sử dụng các công cụ Nmap, Wireshark, Burp Suite), thiết bị mục tiêu là một IP Camera (được mô phỏng bằng Python Web Server), hệ thống mạng bị cấu hình sai (mở cổng Port Forwarding trực tiếp ra Internet) và hệ thống phòng thủ đề xuất (tích hợp VPN/VLAN để bảo vệ thiết bị).



Hình 2.1 - Sơ đồ kiến trúc hệ thống IP Camera mở cổng trực tiếp ra Internet và ranh giới tin cậy

Trong kiến trúc này, Ranh giới tin cậy đã bị phá vỡ một phần do Router NAT trực tiếp luồng traffic từ bên ngoài vào Camera. Mọi thiết bị trên Internet (bao gồm cả kẻ tấn công) đều có thể tương tác trực tiếp với giao diện đăng nhập của Camera mà không cần qua lớp bảo vệ nào khác.

2.2. Các khái niệm bảo mật cốt lõi

Để đánh giá chính xác rủi ro của hệ thống trên, đề tài áp dụng các khái niệm bảo mật chuyên ngành, cụ thể được ánh xạ vào ngữ cảnh thực tế của IP Camera:

Tài sản (Asset): Ở đề tài này, tài sản bao gồm thiết bị IP Camera (được mô phỏng bằng Python), quyền quản trị hệ thống (tài khoản admin) và đặc biệt là luồng dữ liệu video giám sát mang tính riêng tư truyền trên mạng.

Mối đe dọa (Threat): Đề tài sẽ mô phỏng các mối đe dọa trên môi trường thử nghiệm để kiểm chứng mức độ nguy hiểm khi thiết bị phơi bày mạng. Kịch bản dự kiến bao gồm việc dùng Nmap để quét cổng, dùng Wireshark để đánh hơi mạng (Sniffing) và dùng Burp Suite để tấn công vét cạn (Brute-force) tài khoản quản trị.

Lỗ hổng (Vulnerability): Trong mô hình nghiên cứu của đề tài, lỗ hổng xuất hiện do thói quen cấu hình sai (sử dụng Port Forwarding để mở thiết bị trực tiếp ra Internet), truyền tải dữ liệu không mã hóa (HTTP) và thiếu cơ chế bảo vệ tài khoản (không giới hạn số lần nhập sai). Chính vì vậy, đề tài triển khai thực nghiệm nhằm làm rõ tính nghiêm trọng của những lỗ hổng này trước khi đề xuất giải pháp.

Rủi ro (Risk): Xác suất mối đe dọa khai thác thành công lỗ hổng gây ra thiệt hại. *Ví dụ:* Rủi ro mất quyền kiểm soát hệ thống camera dẫn đến việc hình ảnh riêng tư bị rao bán trên mạng.

2.3. Mô hình tấn công, rủi ro và phòng chống

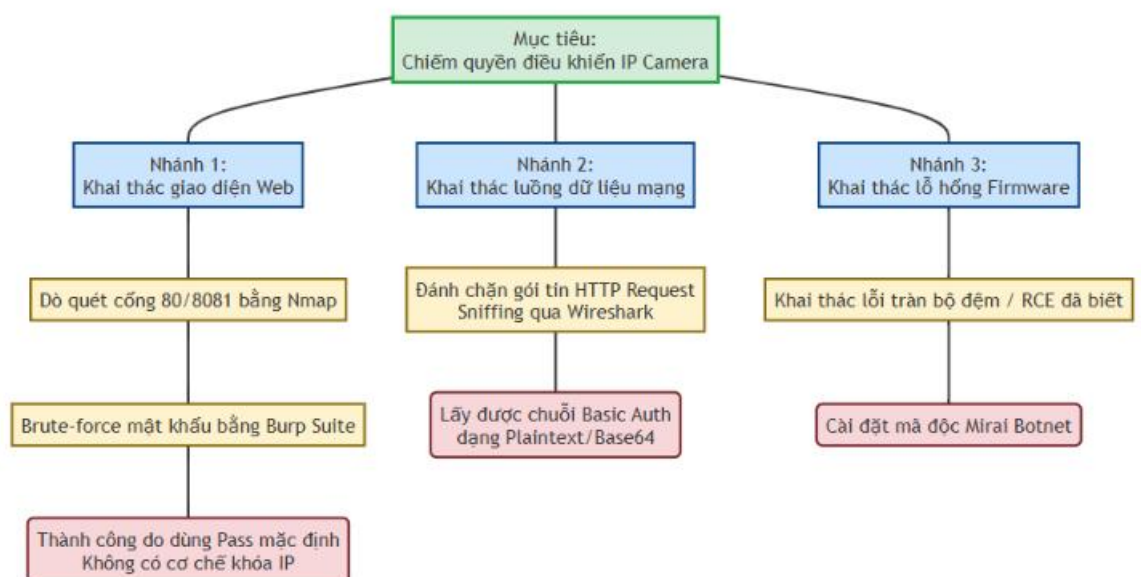
Trọng tâm của đề tài là phân tích kịch bản tấn công nhắm vào các thiết bị IoT bị phơi bày trên Internet.

Điều kiện xảy ra: Tấn công chỉ khả thi khi Camera được gán IP Public hoặc cấu hình Port Forwarding, sử dụng giao thức không mã hóa (HTTP/RTSP) và dùng mật khẩu yếu/mặc định.

Mô hình tấn công: Kẻ tấn công từ xa (Remote Attacker) sẽ dùng công cụ (như Nmap/Shodan) để định vị IP mở cổng. Sau đó, chúng sử dụng các công cụ bẻ khóa tự động (như Burp Suite Intruder) để Brute-force mật khẩu. Nếu hacker ở cùng nhánh mạng (hoặc tấn công Man-in-the-Middle), chúng dùng Wireshark để bắt gói tin (Sniffing) chứa mật khẩu Base64.

Tác động: Kẻ tấn công chiếm toàn quyền thiết bị, xâm phạm đời tư, hoặc biến thiết bị thành công cụ tấn công (Zombie/Botnet).

Phòng chống: Áp dụng phương pháp "Phòng thủ chiều sâu" bằng cách tắt hoàn toàn Port Forwarding, chuyển sang truy cập từ xa qua VPN được mã hóa an toàn, và cô lập Camera vào một VLAN riêng biệt.



Hình 2.2: Sơ đồ Cây tấn công

Mô hình hoạt động dựa trên kịch bản: Kẻ tấn công dò tìm cổng mở, sau đó đánh cắp chuỗi xác thực chưa mã hóa hoặc dùng từ điển dò mật khẩu liên tục cho đến khi chiếm quyền thành công. Để phục vụ quá trình đánh giá, đề tài tập trung vào các thông số như giao thức mạng, cổng dịch vụ, trạng thái mã hóa của gói tin HTTP và phản hồi của máy chủ khi bị Brute-force.

Bảng 2.1: Đánh giá rủi ro theo mô hình STRIDE

Hạng mục STRIDE	Mối đe dọa / Rủi ro cụ thể trên Camera	Kịch bản / Hậu quả	Giải pháp phòng chống (Mitigation)
Spoofing (Giả mạo danh tính)	Kẻ tấn công giả mạo chủ nhà để đăng nhập.	Đăng nhập trái phép bằng mật khẩu bẻ khóa (Brute-force) do thiếu cơ chế khóa tài khoản.	Áp dụng chính sách mật khẩu mạnh, chặn IP sau 5 lần nhập sai, sử dụng xác thực đa yếu tố hoặc VPN.
Tampering (Sửa đổi dữ liệu)	Thay đổi cài đặt cấu hình hoặc firmware của thiết bị.	Hacker đổi DNS của camera sang server độc hại, hoặc thay thế luồng video thật bằng luồng giả.	Cô lập mạng VLAN, vô hiệu hóa tính năng update firmware qua HTTP không bảo mật.
Repudiation	Kẻ tấn công	Camera thường	Cấu hình chuyển

(Chối bỏ trách nhiệm)	công thực hiện hành vi xấu nhưng không bị lưu vết.	không lưu giữ đủ log truy cập (hoặc log dễ bị xóa) khiến quản trị viên không thể truy vết.	Log tập trung (Syslog) ra một máy chủ an toàn khác.
Information Disclosure (Lộ lọt thông tin)	Dữ liệu nhạy cảm truyền trên mạng bị đọc trộm.	Giao thức HTTP và RTSP truyền bản rõ; hacker bắt được tài khoản và xem trộm sinh hoạt riêng tư.	Tắt giao diện HTTP, ép buộc sử dụng HTTPS (TLS/SSL) và kết nối qua đường hầm VPN.
Denial of Service (Từ chối dịch vụ)	Làm tràn ngập tài nguyên thiết bị khiến nó ngưng hoạt động.	Kẻ gian gửi hàng ngàn truy vấn đăng nhập liên tục khiến CPU Camera quá tải (treo máy) và không thể ghi hình.	Đóng cổng NAT ngoài Internet (chặn Inbound). Sử dụng Firewall để giới hạn rate-limit (Tốc độ truy vấn).
Elevation of Privilege (Leo thang đặc quyền)	Khai thác lỗi phần mềm để lấy quyền root (cao nhất).	Lợi dụng một lỗi trong Web server của camera (như tràn bộ đệm) để cài cắm mã độc (Mirai) từ xa.	Thường xuyên cập nhật Firmware từ nhà sản xuất.

2.4. Trọng tâm

Đề tài “Đánh giá rủi ro thiết bị IoT kết nối trực tiếp Internet” thuộc hướng Đánh giá rủi ro và Kiểm thử bảo mật (Vulnerability Assessment & Penetration Testing), tập trung vào việc mô phỏng các kỹ thuật tấn công thực tế để bộc lộ điểm yếu của kiến trúc mạng IoT hiện tại. Trong đó, Python Web Server đóng vai trò là IP Camera mục tiêu chạy ở cổng 8081, còn các công cụ như Nmap, Wireshark và Burp Suite được triển khai để khai thác lỗ hổng.

Mô hình hoạt động dựa trên kịch bản: Kẻ tấn công dò tìm cổng mở, sau đó đánh cắp chuỗi xác thực chưa mã hóa hoặc dùng từ điển dò mật khẩu liên tục cho đến khi chiếm quyền thành công. Để phục vụ quá trình đánh giá, đề tài tập trung vào các thông số như giao thức mạng, cổng dịch vụ, trạng thái mã hóa của gói tin HTTP và phản hồi của máy chủ khi bị Brute-force.

Bảng 2.2. Các đặc trưng được sử dụng trong quá trình thực nghiệm tấn công

Đặc trưng	Ý nghĩa
Địa chỉ IP mục tiêu	Địa chỉ IP tĩnh của IP Camera (Localhost)
Giao thức	TCP/HTTP
Cổng dịch vụ	Cổng 8081 (Giả lập Web Camera)
Header HTTP	Chuỗi Authorization: Basic (Chứa tài khoản/mật khẩu)
Payload tấn công	Danh sách mật khẩu được Burp Suite bắn vào máy chủ
HTTP Status Code	Trạng thái trả về (VD: 200 OK khi hack thành công)

2.5. Tiêu kết Chương 2

Tóm lại, Chương 2 đã làm rõ bối cảnh kiến trúc của thiết bị IP Camera khi bị cấu hình mở cổng trực tiếp ra ngoài Internet, đồng thời hệ thống hóa các rủi ro bảo mật cốt lõi qua mô hình CIA, bảng phân tích STRIDE và sơ đồ Attack Tree. Bằng cách định hình rõ các khái niệm về tài sản, lỗ hổng, mối đe dọa và đánh giá các công trình nghiên cứu trước đó, đề tài đã xây dựng được một cơ sở lý luận vững chắc. Những nền tảng kiến thức này sẽ là tiền đề quan trọng để triển khai kịch bản giả lập, tiến hành thực nghiệm tấn công trực quan và đề xuất các biện pháp phòng chống chi tiết sẽ được trình bày ở Chương 3.

CHƯƠNG 3: CÁC PHƯƠNG PHÁP, MÔ HÌNH, THIẾT KẾ VÀ KẾ HOẠCH ĐÁNH GIÁ

3.1. Phương pháp thực hiện

Đề tài sử dụng phương pháp nghiên cứu kết hợp gồm: mô phỏng, thực nghiệm trong môi trường khép kín, xây dựng mô hình mối đe dọa, phân tích rủi ro và kiểm thử bảo mật (Penetration Testing).

Mô phỏng: Đề tài xây dựng một môi trường giả lập trên nền tảng mạng cục bộ (Localhost). Thay vì sử dụng thiết bị phần cứng vật lý, một mã nguồn Python được lập trình để đóng vai trò là IP Camera mục tiêu (Web Server chạy trên cổng 8081, tích hợp cơ chế Basic Authentication) nhằm phục vụ an toàn cho việc kiểm thử.

Thực nghiệm trong Lab: Các thành phần sẽ được triển khai trên cùng một máy tính thực nghiệm để cách ly rủi ro với Internet. Trong đó, hệ thống giả lập đóng vai trò là Camera bị cấu hình sai (mở Port Forwarding hớ hênh), còn các bộ công cụ chuyên dụng (Nmap, Wireshark, Burp Suite) đóng vai trò là Kẻ tấn công thực thi việc gửi và chặn bắt gói tin qua hệ thống mạng.

Mô hình mối đe dọa: Phương pháp Threat Modeling (cụ thể là mô hình STRIDE) được áp dụng trong đề tài này nhằm xác định các tài sản cốt lõi cần bảo vệ (quyền quản trị thiết bị, luồng video riêng tư, thông tin đăng nhập). Dựa vào kiến

trúc mạng khi Camera bị phơi bày trực tiếp ra Internet, đề tài xác định các nguy cơ tấn công như: quét cổng diện rộng (Port Scanning), đánh hơi dữ liệu truyền tải không mã hóa (Sniffing) và bẻ khóa tài khoản (Brute-force) để làm cơ sở xây dựng kịch bản kiểm thử.

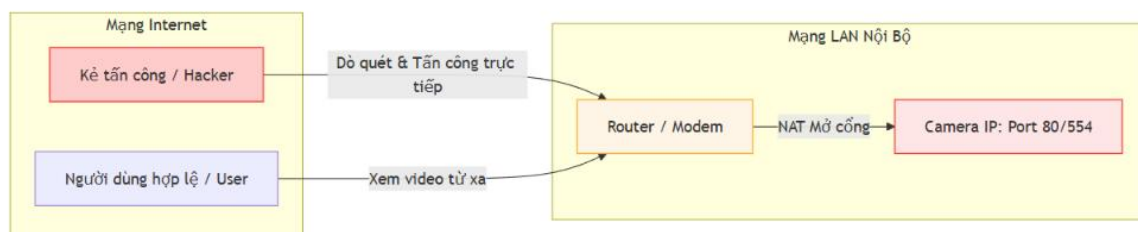
Phân tích rủi ro: Đánh giá mức độ ảnh hưởng và khả năng xảy ra của từng rủi ro đối với thiết bị IP Camera dựa trên hệ thống điểm CVSS. Những rủi ro có mức độ ưu tiên cao nhất, chẳng hạn như việc lộ lọt dữ liệu do dùng giao thức HTTP thuần túy hoặc bị chiếm quyền do thiếu cơ chế khóa tài khoản, được lựa chọn làm trọng tâm để kiểm thử minh chứng.

Kiểm thử bảo mật: Sử dụng công cụ Nmap để quét và xác định dịch vụ đang mở; Wireshark được dùng để chặn bắt và giải mã chuỗi đăng nhập trên đường truyền; Burp Suite (module Intruder) được sử dụng để tấn công vét cạn mật khẩu vào máy chủ Python. Dựa trên kết quả HTTP Status Code và nội dung gói tin bị lộ, đề tài sẽ đánh giá toàn diện mức độ nghiêm trọng của lỗ hổng, qua đó làm cơ sở vững chắc để đề xuất Checklist cấu hình an toàn (ứng dụng VPN/VLAN) nhằm khắc phục triệt để các kịch bản tấn công đã xây dựng.

3.2 Mô hình/kiến trúc đề xuất

Mô hình 1:

Mô hình không an toàn (Insecure): Router cấu hình NAT trực tiếp Port 80 và Port 554 của IP Camera ra IP Public. Thiết bị IoT "nằm trần" trước các luồng truy cập trái phép. Kẻ tấn công có thể tương tác trực tiếp với Camera.



Hình 3.1: Sơ đồ mạng so sánh giữa việc cấu hình sai (Port Forwarding)

Trong mô hình, Router / Modem đóng vai trò là cổng kết nối trọng yếu giữa mạng Internet và Mạng LAN nội bộ. Thiết bị này chịu trách nhiệm định tuyến lưu lượng mạng và đặc biệt là thực thi cơ chế NAT Mở cổng (Port Forwarding). Cơ chế này cho phép chuyển tiếp trực tiếp dữ liệu từ không gian mạng bên ngoài vào thẳng thiết bị IoT bên trong mà bỏ qua các lớp tường lửa bảo vệ thông thường.

Hệ thống được chia thành 2 phân vùng rõ rệt với các thành phần và vai trò như sau:

Phân vùng Mạng LAN Nội Bộ:

Camera IP: Đóng vai trò là thiết bị mục tiêu (tài sản cốt lõi), được cấu hình mở cổng dịch vụ (Port 80 cho giao diện Web, Port 554 cho luồng video RTSP) để sẵn sàng tiếp nhận các kết nối từ xa truyền vào thông qua Router.

Phân vùng Mạng Internet (Bên ngoài): Bao gồm hai đối tượng truy cập vào hệ thống với mục đích hoàn toàn khác biệt:

Người dùng hợp lệ / User: Thực hiện nhiệm vụ kết nối từ xa vào hệ thống thông qua IP Public để theo dõi, xem video giám sát camera. Đây là chủ thể tạo ra các luồng lưu lượng hoạt động bình thường và hợp pháp của hệ thống.

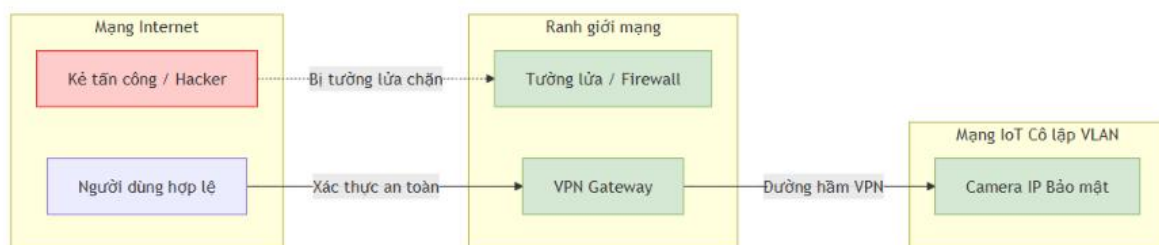
Kẻ tấn công / Hacker: Đại diện cho thiết bị kiểm thử bảo mật (sử dụng bộ công cụ tấn công chuyên dụng). Thành phần này được sử dụng để tạo ra các kịch bản khai thác rủi ro như: dò quét mạng diện rộng, phát hiện cổng mở hờ hênh và thực hiện các mũi tấn công trực tiếp nhằm chiếm quyền điều khiển Camera IP.

Đánh giá kiến trúc:

Kiến trúc này phá vỡ ranh giới an toàn của mạng nội bộ. Việc phơi bày Camera IP một thiết bị vốn có năng lực bảo mật rất kém (thường dùng mật khẩu mặc định, gửi dữ liệu dạng bản rõ Plaintext không mã hóa) ra môi trường Internet. Camera rất dễ dàng bị bẻ khóa, dẫn đến lộ lọt hình ảnh riêng tư hoặc bị lây nhiễm mã độc biến thành một phần của mạng botnet.

Mô hình 2:

Mô hình an toàn (Secure): Thiết bị IP Camera được đặt trong một VLAN cô lập. Người dùng phải đi qua kết nối mã hóa (VPN Tunnel) và tường lửa (Firewall) để truy cập. Mọi truy cập trực tiếp từ Internet (Inbound) hoàn toàn bị chặn đứng.



Hình 3.2: Sơ đồ cấu hình an toàn (dùng VPN/VLAN).

Trong Mô hình này, hệ thống mạng đã được tái cấu trúc để loại bỏ hoàn toàn các rủi ro. Cơ chế Port Forwarding đã được gỡ bỏ thay vào đó, kiến trúc thiết lập một ranh giới mạng (Network Perimeter) vững chắc làm chốt chặn trung gian giữa mạng Internet và không gian mạng nội bộ.

Hệ thống bảo mật mới được chia thành 3 phân vùng độc lập với các cơ chế kiểm soát nghiêm ngặt:

Phân vùng Mạng Internet (Bên ngoài):

Kẻ tấn công / Hacker: Khi thực hiện các hành vi dò quét cổng hoặc tấn công trực tiếp vào địa chỉ IP WAN của hệ thống, mọi luồng dữ liệu độc hại này lập tức bị Tường lửa chặn (Blocked by Firewall). Do không còn cổng dịch vụ nào mở hớ hênh, kẻ tấn công hoàn toàn "mù" trước hệ thống mạng bên trong.

Người dùng hợp lệ: Để truy cập được vào camera từ xa, người dùng bắt buộc phải đi qua quy trình Xác thực an toàn thông qua một phần mềm VPN Client được cài đặt trên thiết bị cá nhân.

Phân vùng Ranh giới mạng (Network Perimeter): Đóng vai trò là cửa ngõ an ninh duy nhất của toàn bộ hệ thống, bao gồm:

Tường lửa (Firewall): Chịu trách nhiệm lọc bỏ các truy cập trái phép từ Internet.

VPN Gateway: Máy chủ Mạng riêng ảo làm nhiệm vụ tiếp nhận yêu cầu xác thực từ người dùng hợp lệ. Sau khi xác thực thành công, Gateway sẽ thiết lập một Đường hầm mã hóa (VPN Tunnel) kết nối trực tiếp thiết bị của người dùng vào mạng nội bộ một cách an toàn.

Phân vùng Mạng IoT Cô lập VLAN:

Camera IP Bảo mật: Thiết bị IoT mục tiêu nay đã được đưa vào một mạng VLAN cô lập, hoàn toàn tách biệt khỏi các thiết bị cá nhân khác (như Laptop, PC) trong mạng LAN. Nhờ đường hầm VPN, người dùng từ bên ngoài Internet có thể kết nối an toàn đến Camera để xem video như thể họ đang đứng ngay trong mạng nội bộ nhà mình, đồng thời ngăn chặn tuyệt đối nguy cơ rò rỉ dữ liệu hay bị chiếm quyền.

3.3. Môi trường, công cụ, dữ liệu

Để đảm bảo tính khách quan và an toàn, toàn bộ quá trình mô phỏng tấn công được thực hiện trên môi trường máy ảo cục bộ (Localhost). Các công cụ phần mềm và phần cứng được sử dụng bao gồm:

Bảng 3.1. Thành phần, công cụ và dữ liệu

Phần mềm / Phần cứng	Phiên bản	Vai trò trong thực nghiệm
Python (Ngôn ngữ lập trình)	3.10.x	Lập trình mã nguồn giả lập Web Server của IP Camera chạy trên cổng 8081 với xác thực Basic Auth.
Nmap	7.93	Thực hiện rà quét mạng (Reconnaissance) để phát hiện IP và các

(Zenmap)		cổng dịch vụ đang mở của thiết bị mục tiêu.
Wireshark	4.0.x	Lắng nghe trên card mạng (Loopback), bắt và phân tích gói tin HTTP/RTSP để chứng minh dữ liệu không được mã hóa (Sniffing).
Burp Suite Community	2023.x	Chặn bắt yêu cầu đăng nhập và sử dụng module Intruder để tự động hóa quá trình tấn công Brute-force mật khẩu.
Máy tính cá nhân (PC/Laptop)	Windows 10/11 (RAM 8GB+)	Đóng vai trò nền tảng phần cứng vừa chạy máy chủ giả lập (Victim) vừa chạy các công cụ tấn công (Attacker).

3.4. Quy trình triển khai/đánh giá

Bảng 3.2. Quy trình thực hiện

Bước	Công việc thực hiện	Kết quả đầu ra (Đầu ra)	Minh chứng trong Repo (File / Hình ảnh)
1	Xây dựng môi trường IP Camera giả lập	Mã nguồn Python Web Server chạy thành công trên cổng 8081 với Basic Auth	src/fake_camera.py, results/camera_running.png

2	Quét cổng và đánh giá rủi ro hở Port (Port Forwarding)	Phát hiện chính xác IP và cổng 8081 đang mở (Open) trên hệ thống	results/nmap_scan_open.png, results/nmap_report.md
3	Phân tích đánh hơi luồng mạng (Sniffing) bằng Wireshark	Bắt và bóc tách thành công chuỗi mật khẩu chưa mã hóa (Plain-text) qua HTTP	results/wireshark_sniff.png
4	Kiểm thử tấn công dò mật khẩu (Brute-force) bằng Burp Suite	Bẻ khóa thành công tài khoản quản trị (trả về mã HTTP 200 OK)	results/burpsuite_bruteforce.png
5	Xây dựng giải pháp phòng thủ và Checklist bảo mật	Bộ Checklist cấu hình (tắt NAT, thiết lập VPN/VLAN) và file cấu hình mẫu	Checklist_Bao_Mat.docx
6	Tổng hợp kết quả và Đánh giá ma trận rủi ro	Báo cáo hoàn chỉnh và Bảng đánh giá rủi ro (Risk Matrix)	report/Tieu_Luan_Hoan_Chinh.pdf, results/Risk_Matrix.md

3.5. Tiêu chí và Ngưỡng đánh giá (Evaluation Criteria)

Để chứng minh tính hiệu quả của cả quá trình mô phỏng tấn công (Red Team), đề tài xây dựng một bộ tiêu chí đánh giá định lượng. Các tiêu chí này bám sát vào những mục tiêu ban đầu và có các ngưỡng đo đếm rõ ràng.

Bảng 3.3: Tiêu chí và Ngưỡng đánh giá

Tiêu chí	Ngưỡng đạt (Yêu cầu cần đạt được)
IP Camera giả lập hoạt động ổn định	Máy chủ Python mở cổng 8081, truy cập thành công giao diện Web và hiển thị thông báo yêu cầu đăng nhập.
Kiểm chứng rủi ro quét mạng (Port Scan)	Công cụ Nmap quét thành công và báo cáo chính xác địa chỉ IP đích cùng trạng thái cổng 8081 là Open (Mở).
Kiểm chứng rủi ro lộ lọt dữ liệu (Sniffing)	Wireshark bắt được luồng giao tiếp HTTP, giải mã thành công chuỗi mật khẩu trong trường Authorization: Basic.
Kiểm chứng tấn công vét cạn (Brute-force)	Module Intruder của Burp Suite trả về HTTP Status Code 200 OK tự động khi bắn trúng Payload (admin:admin).
Xây dựng giải pháp phòng thủ	Hoàn thiện 1 bộ Checklist cấu hình vô hiệu hóa NAT và thiết lập đường hầm VPN/VLAN an toàn.
Tính toàn vẹn của Kịch bản kiểm thử	Triển khai thành công 3/3 kịch bản tấn công trên môi trường Localhost theo đúng nguyên tắc đạo đức học thuật.

CHƯƠNG 4: TRIỂN KHAI VÀ KẾT QUẢ

4.1. Chuẩn bị môi trường và Cài đặt công cụ

Để phục vụ cho quá trình giả lập và kiểm thử tấn công hệ thống IP Camera bị mở cổng NAT trực tiếp, hệ thống Lab cục bộ (Localhost) đã được triển khai cài đặt thực tế với các công cụ sau:

Python (Phiên bản 3.10.x): Môi trường thực thi chính trên Windows, kết hợp với các thư viện tiêu chuẩn như `http.server` và `base64` để biên dịch và chạy file mã nguồn giả lập máy chủ Camera (`fake_camera.py`).

Nmap / Zenmap (Phiên bản 7.93): Cài đặt trực tiếp trên máy chủ thử nghiệm (Attacker Machine) để thực thi các lệnh quét thăm dò cổng dịch vụ (Port Scanning).

Wireshark (Phiên bản 4.0.x): Cài đặt kèm theo driver mạng Npcap để có khả năng lắng nghe (Sniffing) lưu lượng trên bộ tiếp hợp mạng Loopback (127.0.0.1) dành riêng cho giả lập Web Server.

Burp Suite Community Edition (Phiên bản 2023.x): Được cài đặt và cấu hình Proxy Listener tại địa chỉ 127.0.0.1:8080 để đánh chặn và can thiệp trực tiếp vào luồng HTTP Request từ trình duyệt gửi tới Camera.

4.2. Thành phẩm sản phẩm và cấu trúc lưu trữ

Đề tài đã phát triển và tổng hợp được 4 nhóm sản phẩm cốt lõi phục vụ cho việc đánh giá bảo mật:

Mã nguồn (Code): Script Python (`fake_camera.py`) được lập trình chuyên biệt để tạo ra một Web Server đóng vai trò là IP Camera mục tiêu. Code này giả lập lỗ hổng xác thực Basic Auth thiếu mã hóa để phục vụ thử nghiệm.

Cấu hình (Config): Các file cấu hình mạng giả lập ảo (Localhost) và các luật (Rules) cấu hình Proxy chặn bắt HTTP Request trên công cụ Burp Suite Intruder.

Checklist bảo mật: Một danh sách kiểm tra (Checklist) dạng văn bản liệt kê cụ thể các bước cấu hình an toàn cho người dùng cuối (như cách tắt NAT, thay đổi mật khẩu mặc định, thiết lập Firewall và cấu hình kết nối qua VPN).

Bảng biểu phân tích : Bao gồm Bảng đánh giá rủi ro STRIDE, Bảng phân tích thành phần công cụ, và Bảng đo lường đối chiếu kết quả trước/sau khi áp dụng giải pháp.

Cấu trúc Repository và vai trò của từng thư mục

Toàn bộ tài nguyên trên được tổ chức khoa học trong một kho lưu trữ (Repository) nhằm phục vụ việc chuyển giao và báo cáo:

```
BAOMATIOT_DeTai29/  
├── configs/  
├── images/  
├── src/  
├── results/  
├── report/  
└── README.md
```

configs/: Nơi lưu trữ bộ Checklist cấu hình an toàn và các file thông số thiết lập mạng ban đầu. Đóng vai trò là tài liệu hướng dẫn phòng thủ cho người dùng.

src/: Thư mục chứa Mã nguồn (Code). Đóng vai trò duy trì hệ thống Victim hoạt động liên tục (Web Server cổng 8081) để hứng chịu các đợt tấn công từ Red Team.

images/: Lưu trữ các hình ảnh minh họa mang tính lý thuyết, sơ đồ thiết kế.

results/: Lưu trữ các minh chứng tấn công (Log Nmap, file PCAP của Wireshark, ảnh chụp màn hình bẻ khóa thành công). Thư mục này đóng vai trò chứng minh tính xác đáng của các lỗ hổng lý thuyết.

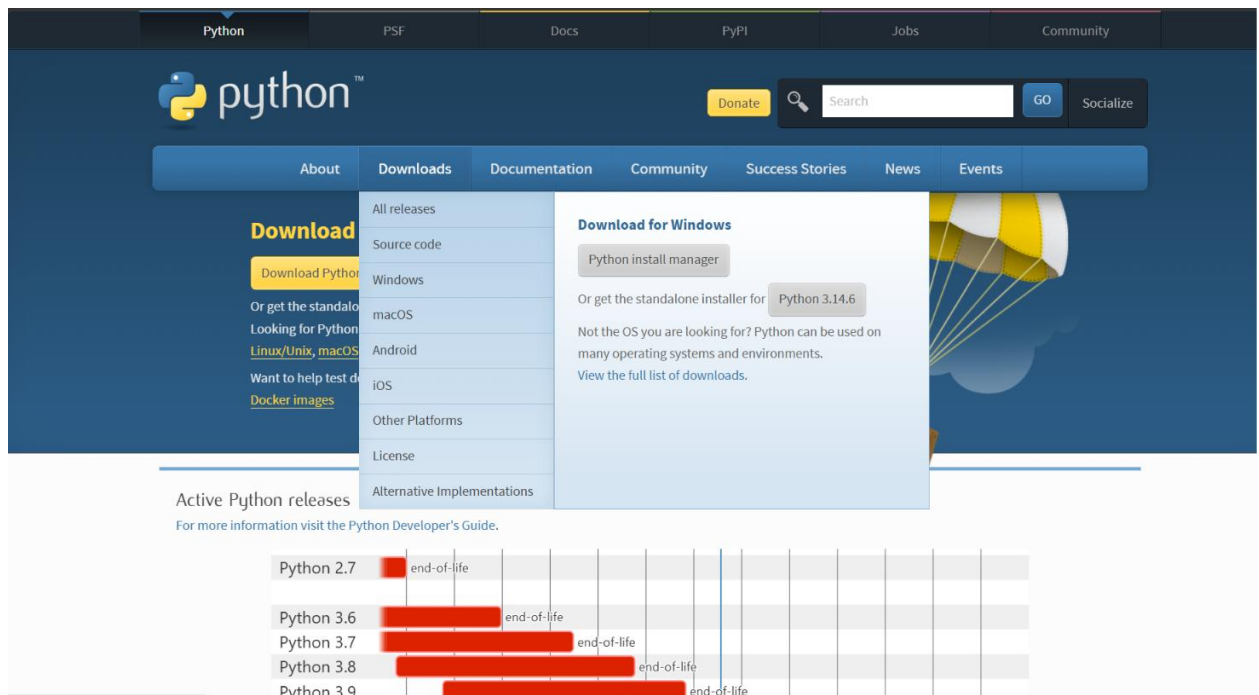
report/: Chứa file Word tiểu luận/báo cáo hoàn chỉnh (và các bảng biểu phân tích đã xây dựng). Đây là tài liệu cốt lõi đóng gói toàn bộ chất xám của đề tài.

4.3. Kịch bản thử nghiệm

Dựa trên kế hoạch đã đề ra, quá trình tấn công giả lập như sau:

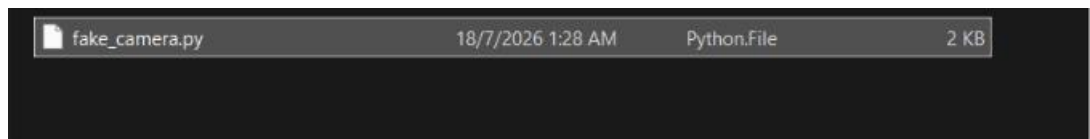
Đầu tiên, dựng Web Server giả lập (Victim) bằng ngôn ngữ Python lắng nghe trên cổng 8081 với cơ chế xác thực Basic Authentication (tài khoản admin:admin)

Bước 1: Cài đặt Python vào máy tính (nếu chưa có).



Hình 4.1: Cài đặt Python vào máy tính

Bước 2: Mở Notepad, tạo một file mới đặt tên là fake_camera.py



Hình 4.2: Tạo file để chạy camera ảo

Với nội dung


```
fake_camera.py
File Edit View

import base64
from http.server import BaseHTTPRequestHandler, HTTPServer

KEY = base64.b64encode(b"admin:admin").decode("ascii")

class FakeCameraHandler(BaseHTTPRequestHandler):
    def do_GET(self):
        if self.headers.get('Authorization') == f'Basic {KEY}':
            self.send_response(200)
            self.end_headers()
            self.wfile.write(b"<h1>Camera Control Panel</h1><p>Welcome Admin! (This is a fake camera for IoT Security Lab)</p>")
        else:
            self.send_response(401)
            self.send_header('WWW-Authenticate', 'Basic realm="IP Camera Login"')
            self.end_headers()
            self.wfile.write(b"Unauthorized - Please login with admin/admin")

if __name__ == "__main__":
    port = 8081
    print(f"[*] Đang chạy IP Camera giả lập tại cổng {port}...")
    print(f"[*] Mô hình duyệt truy cập: http://localhost:{port}")
    print("[*] Nhấn Ctrl+C để dừng server.")

    try:
        HTTPServer(('0.0.0.0', port), FakeCameraHandler).serve_forever()
    except KeyboardInterrupt:
        print("\n[*] Đã tắt server.")
```

Hình 4.3: Nội dung của file fake_camera.py

Bước 3: Mở Command Prompt tại thư mục chứa file, gõ lệnh: python fake_camera.py. Để cửa sổ đó chạy, không được tắt.

```
C:\WINDOWS\system32\cmd. x + v
Microsoft Windows [Version 10.0.26200.8655]
(c) Microsoft Corporation. All rights reserved.

C:\Users\Admin>cd /d e:\BAOMATIOT\

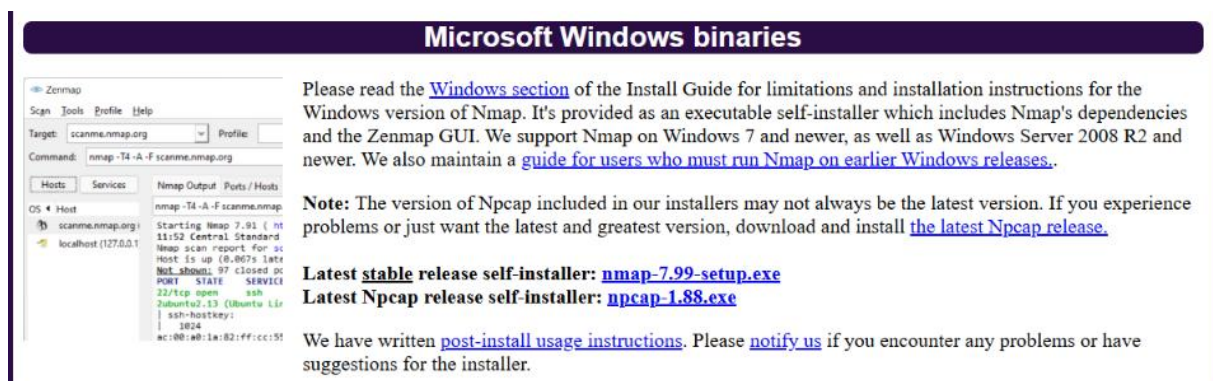
e:\BAOMATIOT>python fake_camera.py
Python was not found; run without arguments to install from the Microsoft Store, or disable the
shortcut from Settings > Apps > Advanced app settings > App execution aliases.

e:\BAOMATIOT>py fake_camera.py
[*] Đang chạy IP Camera giả lập tại cổng 8081...
[*] Mô hình duyệt truy cập: http://localhost:8081
[*] Nhấn Ctrl+C để dừng server.
```

Hình 4.4: Khởi chạy camera ảo

Sau đó sử dụng phần mềm Nmap quét vào địa chỉ localhost để ghi nhận minh chứng công dịch vụ đang mở hớ hênh trên mạng.

Bước 1: Tải và cài đặt phần mềm Nmap (chọn bản có kèm giao diện Zenmap).

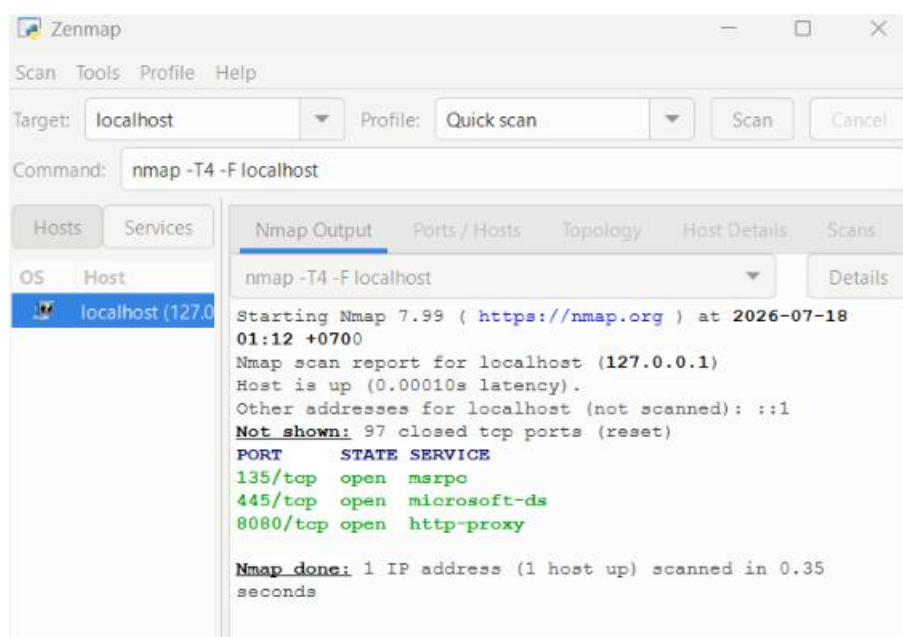


Hình 4.5: Cài đặt phần mềm Nmap trên trang web chính thức

Bước 2: Mở Zenmap lên, ở ô Target bạn nhập: localhost

Bước 3: Ở ô Command, gõ lệnh: nmap -p 8081 localhost. Bấm nút Scan.

Đợi vài giây, kết quả ở dưới sẽ hiện ra dòng 8081/tcp open http



Hình 4.6: Nmap quét rà soát và tìm được camera không có bảo mật hiện tại.

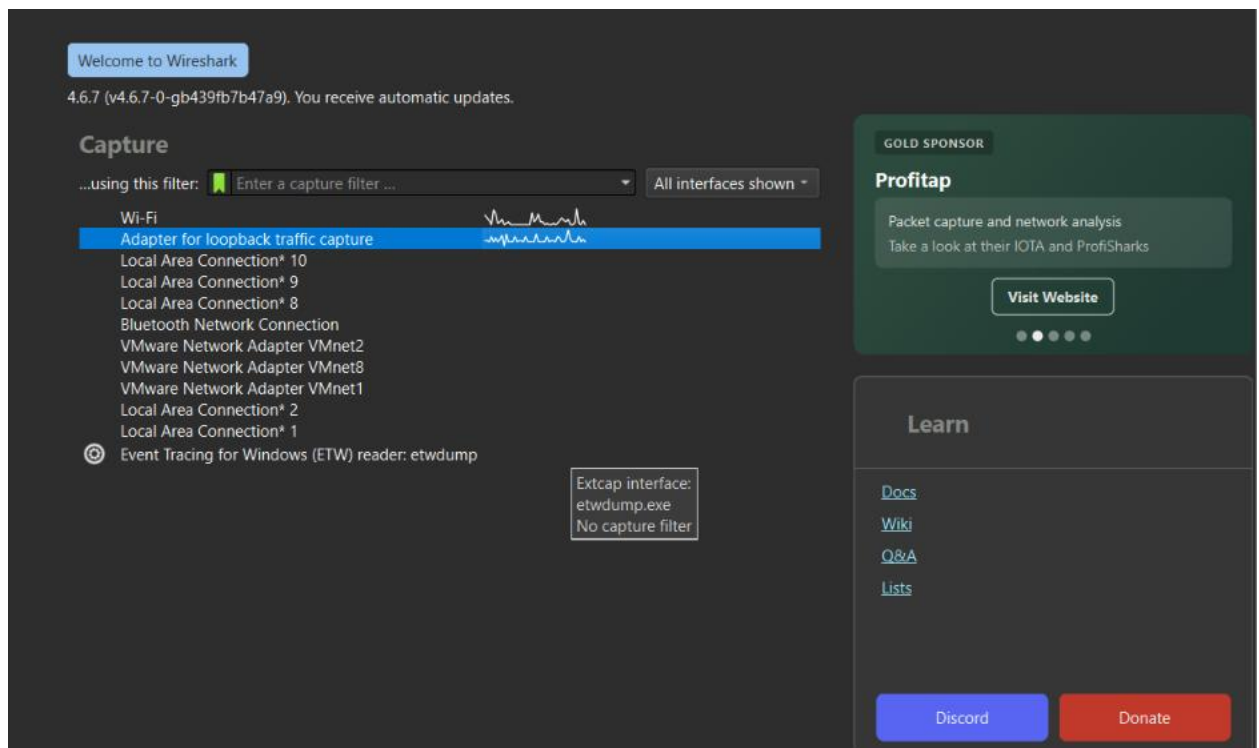
Tiếp đến, mở phần mềm Wireshark lắng nghe lưu lượng trên card mạng Loopback và tiến hành đăng nhập thử trên trình duyệt, từ đó truy xuất luồng HTTP Stream để bắt được gói tin chứa chuỗi tài khoản dạng Base64 chưa được mã hóa an toàn (Authorization: Basic YWRtaW46YWRtaW4=).

Bước 1: Tải và cài đặt Wireshark.



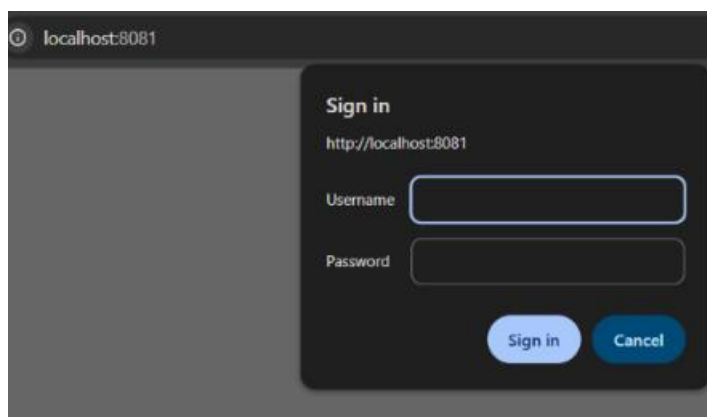
Hình 4.7: Cài đặt Wireshark trên trang trình duyệt

Bước 2: Mở Wireshark, ở giao diện đầu tiên, nhấn đúp chuột vào card mạng có tên là Adapter for loopback traffic capture. Phần mềm sẽ bắt đầu bắt gói tin mạng.

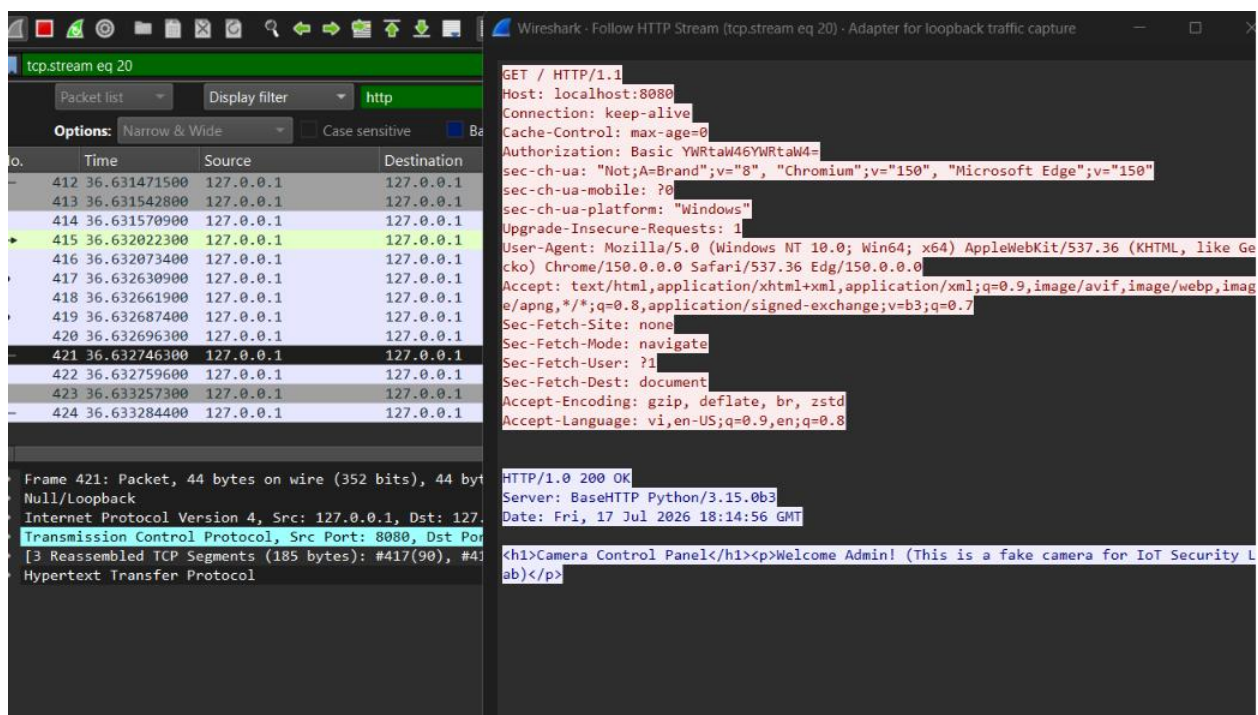


Hình 4.8: Wireshark bắt đầu bắt gói tin của camera.

Bước 3: Mở trình duyệt Web (Chrome/Edge), truy cập vào địa chỉ: <http://localhost:8081>. Trình duyệt sẽ hiện bảng hỏi tài khoản. Nhập User là admin, Password là admin rồi bấm Enter. Quay lại Wireshark, ở thanh lọc (filter) phía trên cùng, gõ tcp.port == 8081 rồi ấn Enter. Sẽ thấy các gói tin hiện ra. Nhấp chuột phải vào gói tin đầu tiên có chữ HTTP (GET / HTTP/1.1) -> Chọn Follow -> Chọn HTTP Stream. Cửa sổ mới hiện ra chữ màu đỏ, sẽ thấy dòng: Authorization: Basic YWRtaW46YWRtaW4=.



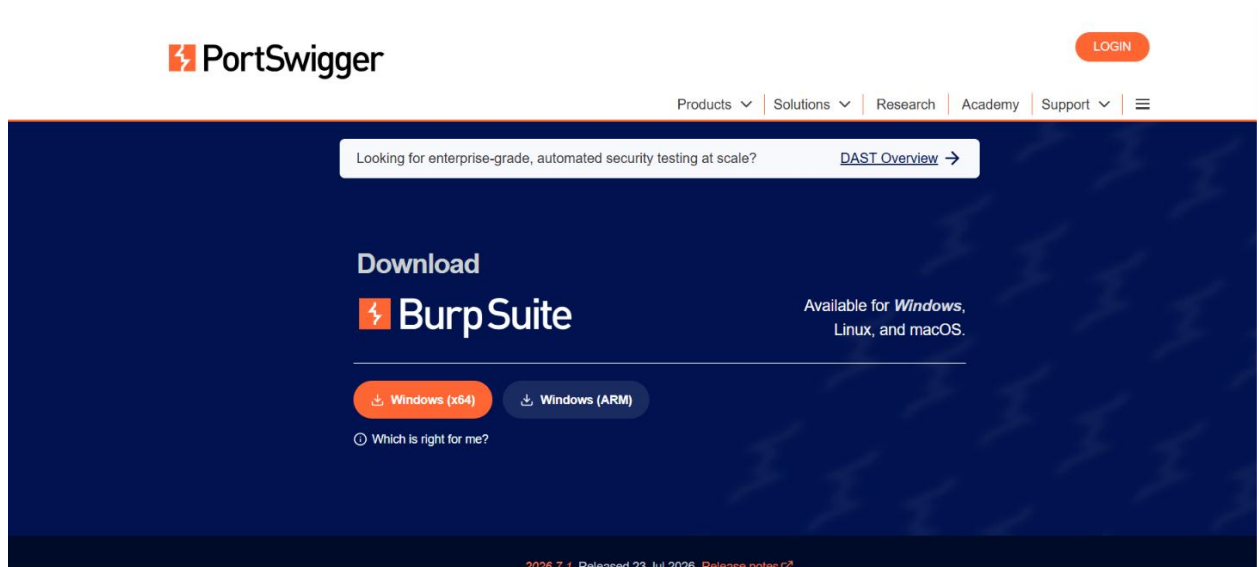
Hình 4.9: Đăng nhập trình duyệt



Hình 4.10: Kết quả bắt gói tin bằng Wireshark cho thấy thông tin đăng nhập (Basic Auth) bị lộ.

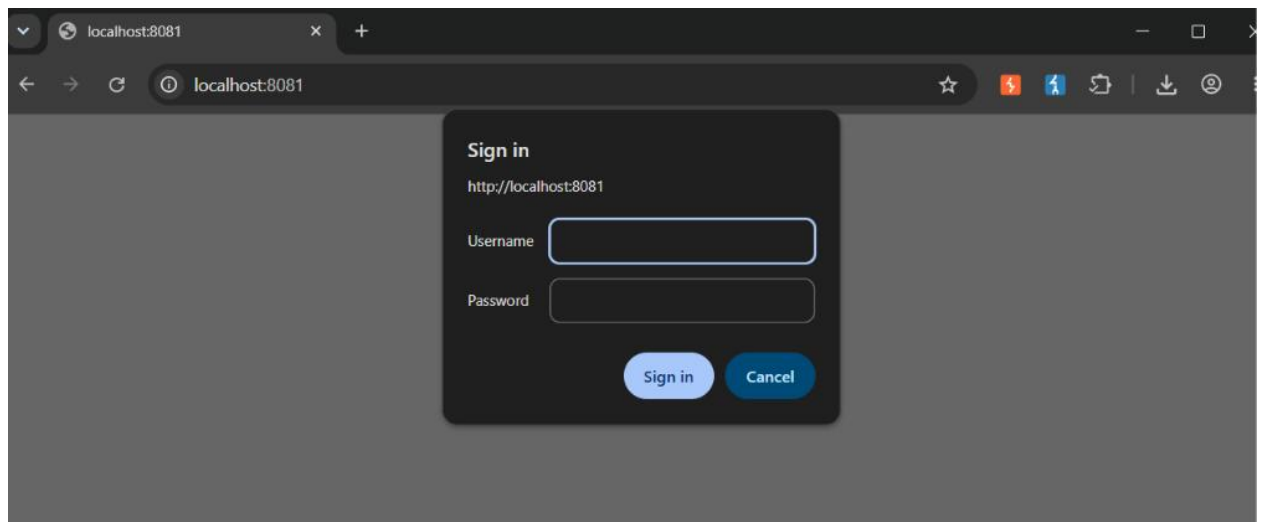
Cuối cùng, để kiểm chứng rủi ro Brute-force, dùng phần mềm Burp Suite chặn gói tin truy cập, chuyển hướng luồng dữ liệu sang module Intruder, nạp một danh sách các mật khẩu phổ biến kèm luật tự động mã hóa Base64, rồi kích hoạt tấn công để thu về minh chứng hệ thống không bị khóa khi nhập sai liên tục và nhanh chóng trả về mã trạng thái HTTP 200 OK ngay khi thử trúng thông tin tài khoản hợp lệ.

Bước 1: Tải và mở bản miễn phí Burp Suite Community Edition. Khởi tạo một Project mặc định. Mở thẻ Proxy -> Bật Intercept is on -> Bấm nút Open Browser (để mở trình duyệt tích hợp của Burp).



Hình 4.11: Cài đặt Burp-Suite trên trình duyệt

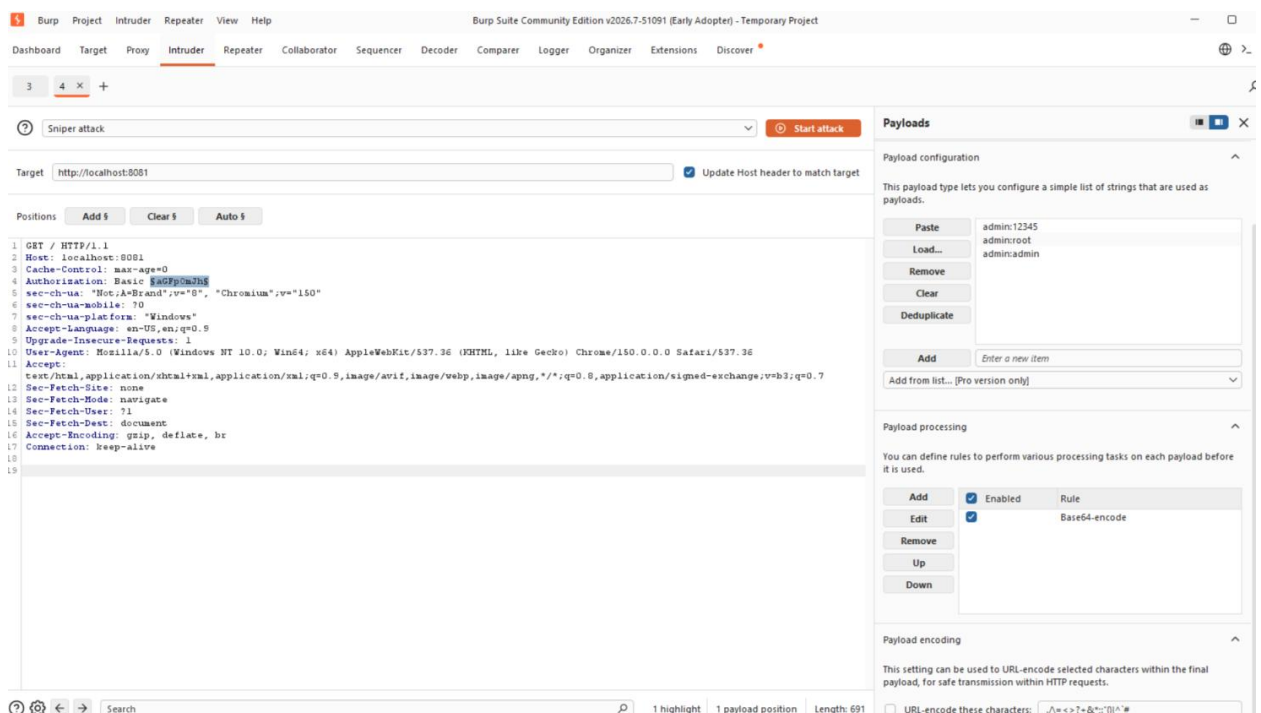
Bước 2: Tại trình duyệt vừa mở lên, truy cập <http://localhost:8081>. Trình duyệt sẽ bị treo do Burp Suite đang chặn gói tin lại. Trở lại giao diện Burp Suite, nhấp chuột phải vào phần khoảng trắng của gói tin đang bị chặn -> Chọn Send to Intruder.



Hình 4.12: Trình duyệt bị treo do chặn gói tin bị chặn.

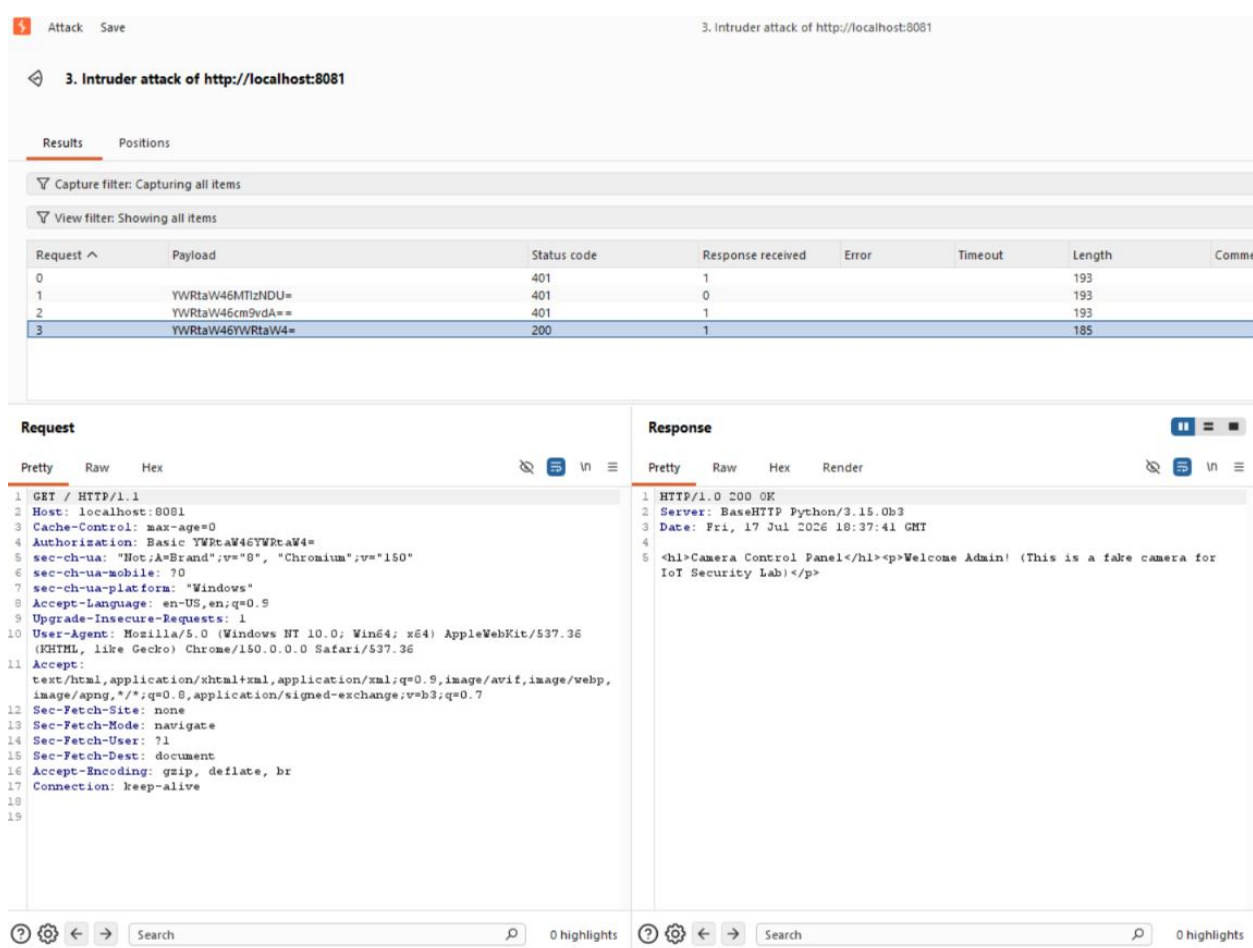
Bước 3: Chuyển sang thẻ Intruder: Vào tab Positions_Bấm nút Clear §. Ở dòng cuối cùng của gói tin, gõ thêm dòng này: Authorization: Basic §payload§ (Quét khối chữ payload rồi bấm nút Add § để tạo biến số).

Bước 4: Vào tab Payloads: Tại mục Payload settings_Bấm Add và nhập admin:1234, admin:password, admin:admin, root:root. Tại mục Payload Processing: Bấm Add -> Chọn Encode -> Chọn Base64-encode.



Hình 4.13: Cấu hình module Intruder trên Burp Suite để thực hiện tấn công Brute-force.

Bước 5: Tắt dấu tick ở ô URL-encode these characters (để nó không làm hỏng dấu bằng = của Base64). Bấm nút Start Attack . Một bảng kết quả sẽ hiện ra. Thấy duy nhất dòng chứa admin:admin trả về mã Status là 200, các dòng khác là 401.



Hình 4.14: Tự động dò quét và bẻ khóa thành công tài khoản quản trị viên.

4.4. Checklist cấu hình an toàn

Dựa trên các kết quả rủi ro thu được từ thực nghiệm, đề xuất một bộ quy tắc bảo mật:

Trong đó ưu tiên hàng đầu là tuyệt đối không cấu hình Port Forwarding (NAT) trực tiếp IP Camera ra mạng Internet, đồng thời phải tắt ngay tính năng UPnP trên

Router để ngăn thiết bị tự động mở cổng. Thay vào đó, để giám sát từ xa một cách an toàn, hệ thống cần được thiết lập thông qua mạng riêng ảo (VPN như Tailscale hoặc WireGuard); kết hợp với việc thay đổi mật khẩu mặc định ngay lần cài đặt đầu tiên thành chuỗi mật khẩu mạnh (tối thiểu 12 ký tự) và chủ động vô hiệu hóa toàn bộ các dịch vụ không sử dụng tới (như Telnet, SSH, FTP hay ONVIF công khai) nhằm thu hẹp tối đa bề mặt tấn công.

4.5. Thảo luận & hạn chế

4.5.1. Thảo luận kết quả

Qua kết quả thực nghiệm cho thấy, hệ thống giả lập đã đáp ứng các mục tiêu đặt ra ở Chương 1. Mã nguồn Python hoạt động ổn định trong vai trò mô phỏng một IP Camera bị phơi bày trực tiếp ra Internet qua cổng 8081. Các công cụ kiểm thử chuyên dụng như Nmap, Wireshark và Burp Suite đã phối hợp khai thác thành công chuỗi lỗ hổng nghiêm trọng: từ việc dò ra cổng dịch vụ (Port Forwarding), đánh cắp mật khẩu bản rõ trên đường truyền không mã hóa (HTTP Sniffing), cho đến việc chiếm đoạt tài khoản bằng tấn công vét cạn (Brute-force). Đối chiếu với các tiêu chí đánh giá đã xây dựng, kết quả thực nghiệm này là minh chứng trực quan và hoàn toàn thuyết phục. Sự mỏng manh của hệ thống trước các mũi tấn công tự động chính là cơ sở thực tiễn vững chắc nhất để đề xuất việc áp dụng Checklist cấu hình phòng thủ (chuyển đổi từ NAT sang VPN/VLAN) nhằm bọc lót toàn diện cho các thiết bị IoT.

4.5.2. Hạn chế

Do giới hạn về điều kiện trang thiết bị và thời gian nghiên cứu, hệ thống kiểm thử mới chỉ được triển khai khép kín trên môi trường giả lập phần mềm (Localhost) nhằm đảm bảo tuân thủ tuyệt đối các nguyên tắc an toàn đạo đức mạng. Đề tài chưa tiến hành đánh giá rủi ro trên các thiết bị IP Camera vật lý (phần cứng thực tế) đến từ nhiều thương hiệu khác nhau trên thị trường.

Bên cạnh đó, bài lab chủ yếu tập trung vào lỗi cấu hình mạng và cơ chế xác thực, chưa bao quát hết các loại hình tấn công phức tạp khác như khai thác lỗ hổng phần mềm (Firmware Exploitation) hay tấn công từ chối dịch vụ (DDoS) từ mạng máy

tính ma (Botnet). Mặc dù vậy, những kết quả thu được đã phản ánh chính xác bản chất cốt lõi của rủi ro IoT, khẳng định tính khả thi của giải pháp bảo mật đề xuất và mở ra hướng ứng dụng rộng rãi trên các mô hình nhà thông minh (Smart Home) thực tế trong tương lai.

CHƯƠNG 5: ĐÁNH GIÁ BẢO MẬT

5.1. Phân loại tài sản và yêu cầu bảo mật

Bảng 5.1: Phân loại tài sản và yêu cầu bảo mật

Tài sản / Dữ liệu	Chủ thể quản lý	Mức quan trọng	Yêu cầu C-I-A	Ghi chú
Web Server giả lập IP Camera	Hệ thống IoT	Cao	C: Trung bình I: Cao A: Cao	Đóng vai trò là mục tiêu chính, nơi cung cấp giao diện điều khiển và luồng video.
Luồng dữ liệu Video / Âm thanh	IP Camera	Cao	C: Cao I: Trung bình A: Cao	Là dữ liệu riêng tư, rất nhạy cảm. Tính bảo mật (C) đòi hỏi cực cao để tránh rò rỉ.
Thông tin xác thực (Tài khoản / Mật khẩu)	Người dùng / Quản trị viên	Rất Cao	C: Cao I: Cao A: Cao	Yếu tố then chốt để bảo vệ thiết bị. Cần được mã hóa khi truyền tải (tránh Sniffing) và bảo vệ khỏi vét cạn.
Cấu hình Router / Tường lửa (Firewall)	Quản trị viên	Cao	C: Cao I: Cao A: Cao	Quy định chính sách định tuyến, quyết định việc đóng/mở cổng (Port

				Forwarding) ra Internet.
Cấu hình VPN & Chia khóa (Keys)	Quản trị viên / Client	Cao	C: Cao I: Cao A: Cao	Đường hầm bảo mật. Nếu lộ Key VPN, kẻ tấn công có thể xâm nhập trực tiếp vào mạng nội bộ.
Hệ thống máy kiểm thử (Kali Linux, Burp Suite)	Người kiểm thử	Trung bình	C: Thấp I: Trung bình A: Cao	Đóng vai trò làm máy trạm tấn công để rà quét và thực thi kịch bản dò mật khẩu.

5.2. Biện pháp giảm thiểu và Hạn chế

Bảng 5.4. Biện pháp giảm thiểu và ưu tiên

Mã rủi ro	Biện pháp giảm thiểu	Chủ thể thực hiện	Chi phí ước tính	Cách xác minh hiệu quả
R-01 (Bị dò quét cổng diện rộng do NAT)	- Xóa bỏ hoàn toàn quy tắc Port Forwarding / NAT đối với Camera trên Router. - Tắt tính năng UPnP.	Người dùng / Quản trị viên mạng	Thấp	Dùng công cụ Nmap quét lại địa chỉ IP Public (WAN) từ bên ngoài Internet, kết quả báo cổng 8081 đã bị đóng (Closed hoặc Filtered).
R-02 (Lộ thông tin đăng tin)	- Triển khai mạng riêng ảo (VPN Server) làm cổng	Quản trị viên mạng	Thấp	Bật Wireshark và bắt gói tin lần nữa. Kết quả chỉ thấy các gói tin mã

nhập do Sniffing HTTP)	kết nối duy nhất từ xa. - Toàn bộ lưu lượng video/xác thực bị ép chạy ngầm qua đường hầm VPN mã hóa.			hóa (như UDP/ESP của VPN), không thể đọc được chuỗi Authorization: Basic bằng mắt thường.
R-03 (Bị bẻ khóa do Brute-force & mật khẩu mặc định)	- Bắt buộc thay đổi mật khẩu mặc định thành mật khẩu mạnh. - Kích hoạt tính năng Account Lockout (Khóa tài khoản sau 5 lần nhập sai) hoặc chặn IP bằng Firewall nếu thiết bị có hỗ trợ.	Người dùng cuối	Thấp	Dùng lại Burp Suite (module Intruder) nã hàng loạt mật khẩu. Kiểm tra thấy sau vài lần thử, hệ thống từ chối kết nối hoặc báo lỗi 403 Forbidden thay vì chỉ báo 401.
R-04 (Bị dùng làm bàn đạp tấn công mạng LAN)	- Thiết lập một VLAN riêng biệt (Mạng khách/IoT) chỉ dành riêng cho Camera. - Cấu hình Firewall không cho Camera giao tiếp với máy tính, điện thoại ở mạng LAN chính.	Quản trị viên mạng	Trung bình	Lấy một máy tính nằm trong VLAN chính (mạng làm việc) thực hiện lệnh ping sang dải IP của Camera, kết quả trả về Request timed out (bị Firewall chặn thành công).

R-05 (Thiết bị tồn tại lỗ hổng Firmware chưa vá)	- Thiết lập lịch kiểm tra và cập nhật Firmware định kỳ từ nhà sản xuất. - Tắt kết nối tính năng Cloud/P2P không cần thiết.	Người dùng cuối	Thấp	Truy cập vào giao diện quản trị của Camera, xác nhận phiên bản phần mềm đang chạy là mới nhất và tính năng Cloud rủi ro đã tắt.
--	---	-----------------	------	---

CHƯƠNG 6: KẾT LUẬN

Đề tài đã triển khai thành công mô hình đánh giá rủi ro an toàn thông tin đối với các thiết bị IoT (cụ thể là IP Camera) khi bị cấu hình phơi bày trực tiếp ra Internet. Quy trình triển khai bao gồm việc xây dựng một Web Server bằng Python để giả lập IP Camera với cơ chế xác thực cơ bản (Basic Authentication), sau đó sử dụng các công cụ kiểm thử bảo mật chuyên dụng như Nmap, Wireshark và Burp Suite để thực thi các kịch bản khai thác lỗ hổng trực tiếp trên môi trường Localhost.

Về cơ bản, đề tài đã chứng minh được các thiết bị IoT trước các tấn công tự động khi hệ thống mạng bị cấu hình sai (lạm dụng Port Forwarding). Song song với việc thực nghiệm quét cổng, đánh hơi dữ liệu và tấn công vét cạn, đề tài cũng đã hoàn thành việc lập mô hình mối đe dọa, đánh giá rủi ro và xây dựng một Checklist cấu hình phòng thủ (ứng dụng Mạng riêng ảo VPN và VLAN). Nhìn chung, các mục tiêu đặt ra ban đầu đều đã được hoàn thành trọn vẹn. Mô hình thực nghiệm đã cho thấy tính cấp thiết của việc loại bỏ NAT và chuyển dịch sang kiến trúc truy cập từ xa an toàn cho hệ sinh thái Smart Home.

6.1. Đối chiếu kết quả thực hiện với mục tiêu đề tài

Bảng 6.1. Bảng đối chiếu kết quả thực hiện với mục tiêu đề tài

Mã mục tiêu	Nội dung mục tiêu	Mức độ hoàn thành	Minh chứng (Chương)
-------------	-------------------	-------------------	---------------------

MT-01	Xây dựng môi trường giả lập IP Camera phục vụ kiểm thử	Hoàn thành	Chương 3 - Thiết kế và triển khai mô hình
MT-02	Chứng minh rủi ro từ việc cấu hình Port Forwarding sai lệch	Hoàn thành	Chương 4 - Kết quả quét mạng bằng Nmap
MT-03	Khai thác lỗ hổng giao thức HTTP thiếu mã hóa bằng Wireshark	Hoàn thành	Chương 4 - Kết quả bắt gói tin (Sniffing)
MT-04	Bẻ khóa tài khoản bằng kỹ thuật tấn công vét cạn (Brute-force)	Hoàn thành	Chương 4 - Kết quả dò mật khẩu Burp Suite
MT-05	Đề xuất giải pháp và xây dựng bộ Checklist cấu hình bảo mật (VPN)	Hoàn thành	Chương 5 - Đánh giá rủi ro và Giải pháp

6.2. Hạn chế

Hạn chế đầu tiên của đề tài là hệ thống mới chỉ được triển khai và đánh giá khép kín trên môi trường giả lập phần mềm (Localhost) để đảm bảo tuân thủ đạo đức học thuật. Đề tài chưa có điều kiện đánh giá trực tiếp trên các thiết bị IP Camera vật lý (phần cứng thực tế) đến từ nhiều thương hiệu khác nhau trên thị trường.

Thứ hai, do phạm vi của đề tài tập trung vào rủi cấu hình mạng và cơ chế xác thực nền tảng web (HTTP), hệ thống chưa đi sâu vào việc kiểm thử các giao thức chuyên biệt khác của Camera như RTSP (truyền phát video) hay ONVIF, vốn cũng chứa đựng nhiều rủi ro bảo mật tiềm tàng.

Hạn chế cuối cùng, đề tài thực hiện các kịch bản tấn công tiêu biểu đứng từ góc độ mạng bên ngoài (External Threat). Các hình thức tấn công phức tạp khác như: dịch ngược phần mềm (Firmware Reversing), khai thác lỗ hổng Zero-day, hay việc

Camera bị lây nhiễm mã độc biến thành mạng máy tính ma (Botnet) chưa được đề cập sâu trong khuôn khổ nghiên cứu này.

TÀI LIỆU THAM KHẢO

- [1] OWASP (Open Worldwide Application Security Project). (2023). OWASP Internet of Things (IoT) Project. <https://owasp.org/www-project-internet-of-things/> . Truy cập ngày 10/7/26. Tài liệu tham khảo về các lỗ hổng bảo mật phổ biến trên thiết bị IoT.
- [2] Lyon, G. F. (2009). Nmap Network Scanning: The Official Nmap Project Guide to Network Discovery and Security Scanning. Nmap Project. <https://nmap.org/book/man.html> . Truy cập ngày 16/7/26. Sử dụng làm cơ sở lý thuyết cho hoạt động rà quét cổng và mạng.
- [3] Chappell, L. (2012). Wireshark Network Analysis: The Official Wireshark Certified Network Analyst Study Guide. Protocol Analysis Institute. https://www.wireshark.org/docs/wsug_html_chunked/. Truy cập ngày 14/7/26 Cơ sở lý thuyết cho kỹ thuật bắt gói tin Sniffing và phân tích giao thức mạng.
- [4] PortSwigger. (2024). Burp Suite Documentation & Web Security Academy. <https://portswigger.net/web-security>. Truy cập ngày 14/7/26. Tài liệu về kỹ thuật bẻ khóa xác thực Basic Auth và tấn công Brute-force.
- [6] Python Software Foundation. (2024). Python 3.10 Documentation - http.server. <https://docs.python.org/3/library/http.server.html>. Truy cập ngày 10/7/26. Tài liệu chính thức được sử dụng để lập trình giả lập máy chủ Web Camera.